

CONFIDENTIAL SECURITY ASSESSMENT

# MedTech HR ERP

## End-to-End Cybersecurity Audit

Production baseline, application and API security, identity, Google Cloud, VM, containers, PostgreSQL, storage, secrets, Microsoft integrations, monitoring, backups, and incident readiness

|          |      |        |     |
|----------|------|--------|-----|
| 0        | 5    | 11     | 4   |
| CRITICAL | HIGH | MEDIUM | LOW |

|                     |                                                                                                 |
|---------------------|-------------------------------------------------------------------------------------------------|
| Assessment          | End-to-end production and synthetic-clone cybersecurity audit                                   |
| Environment         | Google Cloud project hr-erp-502412 / medtech-hr-erp                                             |
| Final source marker | b26c7e212f3c4bb26fff998c91835bd1c3629e72                                                        |
| Safety              | Production read-only; active payloads confined to synthetic data; no production change by audit |
| Classification      | Confidential — no passwords, tokens, raw PII, or sensitive screenshots included                 |

Technical point-in-time assessment • 31 August 2026 • Qatar control mapping is not legal advice

# Contents

Sections and subsections in the final report.

|                                                            |           |
|------------------------------------------------------------|-----------|
| <b>Contents</b>                                            | <b>2</b>  |
| <b>1. Executive summary</b>                                | <b>5</b>  |
| Overall result . . . . .                                   | 5         |
| Strong controls confirmed . . . . .                        | 5         |
| Highest-priority actions . . . . .                         | 5         |
| <b>2. Authorization, safety model, and limitations</b>     | <b>6</b>  |
| 2.1 Authorized lanes . . . . .                             | 6         |
| 2.2 Stop conditions . . . . .                              | 6         |
| 2.3 Important limitations . . . . .                        | 6         |
| <b>3. Method and evidence integrity</b>                    | <b>6</b>  |
| 3.1 Source and deployment timeline . . . . .               | 7         |
| 3.2 Sanitized evidence catalog . . . . .                   | 8         |
| <b>4. Architecture, trust boundaries, and crown jewels</b> | <b>9</b>  |
| 4.1 Data flow . . . . .                                    | 9         |
| 4.2 Trust boundaries . . . . .                             | 9         |
| 4.3 Crown-jewel data . . . . .                             | 10        |
| <b>5. Complete coverage ledger</b>                         | <b>10</b> |
| 5.1 Platform and assets . . . . .                          | 11        |
| 5.2 Roles and authorization personas . . . . .             | 12        |
| 5.3 Endpoint inventory . . . . .                           | 12        |
| 5.4 Integrations . . . . .                                 | 13        |
| 5.5 Scheduled and operational jobs . . . . .               | 13        |
| <b>6. Confirmed findings</b>                               | <b>13</b> |

|                                                                                                                  |           |
|------------------------------------------------------------------------------------------------------------------|-----------|
| CYB-001 — High — Super Administrator can bypass recent step-up authentication . . . . .                          | 14        |
| CYB-002 — High — API connects to PostgreSQL as the postgres superuser . . . . .                                  | 14        |
| CYB-003 — High — Plaintext backups and HR PDFs exist in operator/deployment directories . . . . .                | 14        |
| CYB-004 — High — Security monitoring is incomplete and health metrics are stale/incorrect . . . . .              | 14        |
| CYB-005 — High — Microsoft employee onboarding/login enablement violates the identity-binding sequence . . . . . | 15        |
| CYB-006 — Medium — Production is directly exposed without the expected Cloudflare/WAF layer . . . . .            | 15        |
| CYB-007 — Medium — Upload validation accepts content that does not match the declared MIME type . . . . .        | 15        |
| CYB-008 — Medium — Container hardening, resource controls, and image provenance are incomplete . . . . .         | 15        |
| CYB-009 — Medium — Backup/release/security-baseline retention exceeds governed lifecycle . . . . .               | 15        |
| CYB-010 — Medium — Secret rotation and expiry governance is incomplete . . . . .                                 | 16        |
| CYB-011 — Medium — Entra governance lacks verified tenant-wide access policy and application ownership . . . . . | 16        |
| CYB-012 — Medium — Administrative host access lacks OS Login 2FA and retains stale Docker-group users . . . . .  | 16        |
| CYB-013 — Medium — Tracked and installed edge configuration are not reconciled . . . . .                         | 16        |
| CYB-014 — Medium — Twenty PostgreSQL constraints remain NOT VALID . . . . .                                      | 16        |
| CYB-015 — Medium — Supported dependency vulnerabilities remain in production dependency graphs . . . . .         | 16        |
| CYB-016 — Medium — Backend CSV exports do not neutralize spreadsheet formulas . . . . .                          | 17        |
| CYB-017 — Low — Internal PostgreSQL transport is not encrypted . . . . .                                         | 17        |
| CYB-018 — Low — Assurance scripts and lint are not consistently green . . . . .                                  | 17        |
| CYB-019 — Low — Host discovery/agent listeners are broader than needed . . . . .                                 | 17        |
| CYB-020 — Low — Default log retention and key management need a documented decision . . . . .                    | 17        |
| <b>7. Attack-path analysis</b>                                                                                   | <b>17</b> |
| 7.1 Local administrator compromise to tenant-wide control . . . . .                                              | 17        |
| 7.2 Host/operator compromise to bulk HR data . . . . .                                                           | 18        |
| 7.3 Internet abuse against a directly exposed origin . . . . .                                                   | 18        |
| 7.4 Identity onboarding inconsistency . . . . .                                                                  | 18        |
| <b>8. Automated-analysis and manual-triage ledger</b>                                                            | <b>19</b> |
| ZAP false-positive detail . . . . .                                                                              | 19        |
| <b>9. Control-framework mapping</b>                                                                              | <b>19</b> |

|                                                               |           |
|---------------------------------------------------------------|-----------|
| <b>10. Remediation roadmap</b>                                | <b>20</b> |
| Immediate containment and first 7 days . . . . .              | 20        |
| Within 30 days . . . . .                                      | 20        |
| Within 90 days . . . . .                                      | 20        |
| Owned backlog . . . . .                                       | 20        |
| <b>11. Residual risk and explicitly Not Verified controls</b> | <b>21</b> |
| <b>12. Production safety and cleanup attestation</b>          | <b>21</b> |
| <b>13. Conclusion</b>                                         | <b>21</b> |

# 1. Executive summary

The audit found a generally sound application-security foundation surrounded by several high-impact identity, database-privilege, sensitive-file, and detection weaknesses. Production remained available and was not changed by the audit. All production requests were passive, read-only, and rate-limited; no production credentials were provided, so authenticated production flows were not exercised. Active payloads, malware samples, identifier substitution, malformed DTOs, and rate-limit probes were confined to a disposable clone populated only with synthetic identities.

No confirmed Critical issue was found. Five High, eleven Medium, and four Low findings are recorded. The most important actions are to remove the local password-only Super Administrator's step-up bypass, stop the API from connecting as the PostgreSQL superuser, remove plaintext database and HR-document copies from operator/deployment directories, repair security monitoring, and correct Microsoft identity-onboarding sequencing.

The Microsoft requirement is explicit and is treated as a security and access-control invariant:

- A new @med-tech.com employee must be provisioned in Microsoft Entra ID, bound to the returned Entra object ID, and only then have Microsoft login enabled.
- Changing an existing employee's email to @med-tech.com must run the same onboarding and binding flow before Microsoft login is enabled.
- Provisioning, local persistence, and login enablement must behave atomically from the operator's perspective. If provisioning fails, the application must retain a safe disabled state and return a controlled, actionable error rather than 500.

The production database constraint correctly prevents Microsoft login from being enabled without an Entra object ID. The application currently attempts that invalid sequence, causing the protected write to fail. This is a confirmed control-integration defect, not a recommendation to weaken the database constraint.

## Overall result

| Rating   | Count | Meaning                                                                                                                          |
|----------|-------|----------------------------------------------------------------------------------------------------------------------------------|
| Critical | 0     | No confirmed direct path to immediate catastrophic compromise was reproduced.                                                    |
| High     | 5     | Material identity, privilege, data-exposure, or detection risk requiring action within 30 days; containment sooner where stated. |
| Medium   | 11    | Defense-in-depth or control-integrity gaps requiring action within 90 days.                                                      |
| Low      | 4     | Owned backlog items and assurance improvements.                                                                                  |

## Strong controls confirmed

- Public API handlers use global JWT, CSRF, and permission guards; all 207 handler definitions and 217 route patterns had an explicit public or permission policy.
- Microsoft OIDC uses PKCE, state, nonce, single-tenant issuer/audience/tenant/object-ID validation, server-side session tracking, revocation, and secure \_\_Host- cookies.
- DTO validation uses a strict whitelist; JSON bodies are capped; password verification uses bcrypt with an accepted cost range and a dummy hash for account-enumeration resistance.
- Durable throttling, CSRF enforcement, session tamper rejection, role/department scope checks, and mass-assignment rejection passed targeted tests.
- GCS buckets enforce public-access prevention and uniform bucket-level access. Backup retention and write-only backup service-account behavior are materially stronger than ordinary operator access.
- Service accounts had no user-managed keys. The VM service account did **not** have the hypothesized project Editor role; it had only logging and monitoring writer roles.
- Secure Boot, vTPM, integrity monitoring, OS Login, IAP-only SSH firewall access, unattended upgrades, audit-chain verification, and ClamAV scanning were present.
- The clone rejected EICAR, rejected oversized uploads, rejected malicious DTO fields, rejected tampered sessions and missing CSRF tokens, and rate-limited repeated failed logins.

## Highest-priority actions

- 1 Require phishing-resistant or equivalent MFA/step-up for every Super Administrator, including break-glass accounts; remove the code-level Super Admin bypass.
- 2 Move the API from PostgreSQL postgres to the existing least-privileged application role and keep migrations on a separate migrator identity.

- 3 Remove and securely govern plaintext SQL backups and generated HR PDFs in OneDrive and deployment directories; correct world-readable/world-writable modes.
- 4 Repair false health metrics and add detections for privilege changes, audit tamper, anomalous secret access, malware-scanner failure, container compromise, and exfiltration.
- 5 Implement the Microsoft provisioning/binding/login-enable sequence for both new hires and existing employee email changes, with rollback and deterministic error handling.

## 2. Authorization, safety model, and limitations

### 2.1 Authorized lanes

| Lane            | Permitted                                                                               | Actually performed                                                                                                                                   |
|-----------------|-----------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------|
| Production      | Passive/read-only inspection, one request per second, login/logout session writes only  | Read-only cloud/host/container/database metadata; passive HTTP/TLS/header/route checks; no production login because credentials were not supplied    |
| Synthetic clone | Active scanning, fuzzing, malicious payloads, bounded concurrency/resource tests, EICAR | Full synthetic RBAC integration suite, active API probes, bounded login-rate test, EICAR, MIME mismatch, oversized upload, OWASP ZAP active API scan |
| Restore drill   | Existing isolated drill once, 22:00–02:00 AST, preflight gated                          | <b>Not run:</b> the assessment ended outside the approved execution window                                                                           |

No HR records, IAM policies, application settings, secrets, services, containers, deployments, or production data were changed by this audit. A separate operator changed and redeployed production while evidence collection was in progress; that event is documented as environmental drift, not an audit action.

### 2.2 Stop conditions

Production active testing was prohibited. Read-only checks would stop on a new 5xx, lockout, alert, degraded container, less than 2 GiB available memory, or less than 10 GiB free disk. One IAP SSH connection was transiently closed; public health remained 200, a retry succeeded, approximately 4.9 GB memory was available, approximately 52.8 GB disk was free, and all Compose services were healthy. No stop threshold was crossed.

### 2.3 Important limitations

- No designated production credentials were supplied. Production login, logout, session-expiry, step-up, and cross-role reads are **Not Verified** at runtime; their implementation and synthetic-clone behavior were reviewed/tested.
- Microsoft Security Defaults could not be read with the available Graph permission and is **Not Verified**. No live Conditional Access policy was returned.
- Organization Policy Service access was unavailable/not enabled, so organization-policy controls are **Not Verified**.
- Exact vulnerability scanning of the production-only built image was not completed; clean source, lockfiles, Dockerfiles, Compose, and clone-built artifacts were scanned instead.
- The restore script was reviewed, including checksum, isolation, and trap cleanup, but the approved restore drill was outside the allowed time window and is **Not Verified**.
- Vendor physical controls, HR screening, contractual controls, Microsoft internal controls, and a full incident-response tabletop require organizational evidence and are **Not Verified**.

## 3. Method and evidence integrity

The running deployment was treated as authoritative. Evidence was sanitized at collection: no passwords, tokens, secret values, raw database rows, employee identifiers, personal data, or sensitive screenshots are included in this report or the risk register.

3.1 Source and deployment timeline

| Event                                                    | Result                                                                  |
|----------------------------------------------------------|-------------------------------------------------------------------------|
| Historical deployed commit supplied for comparison       | c11d547ea5bace59f48267f2f840c75729cf96cf                                |
| Reconciliation commit supplied for comparison            | c8552d28e6bd62403fd993656ae838440cbcb6a4                                |
| Earlier main supplied for comparison                     | 29513647716511913e4181e691bcaf184f0f093b                                |
| Initial clear-box/runtime commit observed                | 39f1842a6d0c95cbaa25898eab40057f2d7dcac5                                |
| Final local HEAD, origin/main, and live .deployed-commit | b26c7e212f3c4bb26fff998c91835bd1c3629e72                                |
| Clean final snapshot archive SHA-256                     | 22D085B5049408CA97CDF25234CF405FBAF2DACD548D2E6D220D96B518C41406        |
| Active ZAP image digest                                  | sha256:781a2bdaea47324e7bab583e2263f21d257b0aee61ed51521a5be45f5f5081ef |

Production was redeployed by another operator during the audit. The API container was recreated at approximately 11:33 AST and the web container at approximately 12:03 AST. The deeper source/integration scan used 39f1842; the six-file security-relevant delta through b26c7e2 was manually reviewed, then final frontend tests/build, RBAC regression, public edge checks, and live deployment-marker checks were repeated against the final state. The delta added server-side department scoping for manager announcements and removed session metadata from browser session storage; no new authorization bypass was identified.

## 3.2 Sanitized evidence catalog

| Evidence | Description                                                                                                                      |
|----------|----------------------------------------------------------------------------------------------------------------------------------|
| E-001    | GCP project, VM, firewall, IAM, service-account, key, shielded-VM, and host baseline                                             |
| E-002    | Source/deployment commits, clean snapshot hash, tracked-versus-installed configuration comparison                                |
| E-003    | DNS, TLS protocol/certificate, Nginx, headers, cache, error, and public-route observations                                       |
| E-004    | Host listeners, SSH, sudo, OS Login, patch, local-account, memory, disk, and systemd/timer review                                |
| E-005    | Compose, container identity/capabilities/mount/network/resource/image review                                                     |
| E-006    | PostgreSQL roles, grants, HBA, TLS, schema constraints, audit-chain, session/account aggregate checks                            |
| E-007    | GCS IAM/configuration, backup inventory aggregates, lifecycle, retention, soft delete, and backup-script review                  |
| E-008    | Secret Manager metadata, IAM, version, schedule, and key inventory; values were never read                                       |
| E-009    | Entra applications, permissions, owners, authorization policy, Conditional Access, and Exchange application RBAC                 |
| E-010    | Cloud Logging, Ops Agent, custom metrics, alerting, uptime, channels, and detection-use-case review                              |
| E-011    | Controller/decorator inventory: 207 handlers and 217 route patterns                                                              |
| E-012    | Unit, security, RBAC, integration, financial, leave, document, linking, concurrency, build, lint, migration, and Compose results |
| E-013    | npm audit, Semgrep, Gitleaks history scan, and Trivy filesystem/IaC results with manual triage                                   |
| E-014    | Rate-limited passive production HTTP/TLS checks and final health verification                                                    |
| E-015    | Synthetic exact-schema integration result and controlled clone-only constraint-bypass rerun for remaining coverage               |
| E-016    | Synthetic active API probe results: session, CSRF, EICAR, MIME, size, DTO, and rate-limit behavior                               |
| E-017    | OWASP ZAP active report and manual false-positive triage                                                                         |
| E-018    | Clone cleanup proof, result hashes, audit-VM deletion, and final production health/resource check                                |
| E-019    | File metadata only for plaintext backups and generated PDFs; no content was opened                                               |
| E-020    | Restore drill script review: preflight, SHA-256, isolated network/volume, transient containers, and trap cleanup                 |
| E-021    | Final live deployment marker and healthy container state after the external redeploy                                             |



## 4. Architecture, trust boundaries, and crown jewels

### 4.1 Data flow

#### Internet

- > public DNS and Let's Encrypt TLS
- > VM public IP, host Nginx (Cloudflare tunnel inactive)
- > web container and /api reverse proxy
- > NestJS API container
  - > PostgreSQL 16
  - > ClamAV
  - > Google Cloud Storage documents bucket
  - > Secret Manager
  - > Microsoft Entra ID / Microsoft Graph
  - > isolated Microsoft provisioning broker
  - > Exchange Online mail application
  - > Cloud Logging / Monitoring
- > backup script
  - > pg\_dump + SHA-256 manifest
  - > write-only backup service account
  - > retained GCS backup bucket

### 4.2 Trust boundaries

| Boundary                              | Principal/data crossing                      | Status                   | Evidence            |
|---------------------------------------|----------------------------------------------|--------------------------|---------------------|
| Internet to public VM edge            | Untrusted HTTP/TLS and client IP metadata    | Tested                   | E-003, E-014        |
| Host Nginx to web/API containers      | Proxied headers, routes, request bodies      | Reviewed/Tested          | E-003, E-005, E-014 |
| API to PostgreSQL                     | Credentials, HR/payroll data, audit records  | Reviewed                 | E-006               |
| API to ClamAV                         | Uploaded untrusted files                     | Tested                   | E-005, E-016        |
| API to GCS                            | HR documents and object keys                 | Reviewed                 | E-007               |
| API/host to Secret Manager            | Runtime secret versions                      | Reviewed                 | E-008               |
| Browser/API to Entra OIDC             | Authentication redirects, codes, claims      | Reviewed/Tested in clone | E-009, E-012        |
| API to provisioning broker/Graph      | Application identity and employee onboarding | Reviewed/Tested in clone | E-009, E-015        |
| API to Exchange mail                  | Leave/announcement notification data         | Reviewed                 | E-009, E-012        |
| Host/containers to Logging/Monitoring | Security and operational telemetry           | Reviewed                 | E-010               |
| PostgreSQL/host to backup bucket      | Database dump, manifest, releases            | Reviewed                 | E-007, E-020        |
| Operators/OS Login to VM/Docker       | Root-equivalent administrative control       | Reviewed                 | E-004, E-005        |

4.3 Crown-jewel data

| Data class                                 | Security objective                                   | Observed stores/flows                      | Status                         |
|--------------------------------------------|------------------------------------------------------|--------------------------------------------|--------------------------------|
| Identity and access                        | Correct binding, MFA, least privilege, revocation    | PostgreSQL, Entra, sessions, audit log     | Reviewed/Tested                |
| QID, visa, and employee identity documents | Confidentiality, limited purpose, retention          | PostgreSQL, GCS, exports/backups           | Reviewed                       |
| Payroll, bank, loan, and settlement data   | Confidentiality and tamper resistance                | PostgreSQL, PDFs, exports, backups         | Reviewed/Tested                |
| HR documents and uploads                   | Malware resistance, authorization, integrity         | GCS, ClamAV, API                           | Tested                         |
| Credentials and sessions                   | Non-disclosure, rotation, revocation                 | Secret Manager, cookies, database sessions | Reviewed/Tested                |
| Audit exports and security logs            | Integrity, completeness, controlled access           | PostgreSQL, Cloud Logging, GCS baselines   | Reviewed                       |
| Backups and restore artifacts              | Confidentiality, deletion resistance, recoverability | GCS and local/operator copies              | Reviewed; restore Not Verified |

5. Complete coverage ledger

Tested means a runtime or automated check was executed. Reviewed means configuration/source/evidence was inspected. Not Verified means the available authority or approved window was insufficient. Nothing in the discovered inventory is silently treated as passed.

## 5.1 Platform and assets

| Asset/control         | Result                          | Key observation                                                                                                | Evidence            |
|-----------------------|---------------------------------|----------------------------------------------------------------------------------------------------------------|---------------------|
| Public DNS and TLS    | Tested                          | Direct public A record; TLS 1.2/1.3; no TLS 1.0/1.1; certificate expires 2026-10-24                            | E-003, E-014        |
| Cloudflare            | Reviewed                        | Tunnel inactive; direct host Nginx is authoritative                                                            | E-003               |
| GCP project IAM       | Reviewed                        | Runtime SA not Editor; one Google service agent has Editor; human administrative access concentrated           | E-001               |
| Organization policies | Not Verified                    | Organization Policy API unavailable/not enabled                                                                | E-001               |
| VM                    | Reviewed/Tested                 | Shielded VM controls enabled; public IP present; production health remained good                               | E-001, E-018        |
| Firewall              | Reviewed                        | IAP-only SSH; worldwide 80/443; old default rules disabled                                                     | E-001               |
| OS Login and SSH      | Reviewed                        | OS Login enabled; OS Login 2FA disabled; root/password login disabled                                          | E-004               |
| Sudo/local users      | Reviewed                        | Current OS Login admin has passwordless sudo; locked stale accounts remain in Docker group                     | E-004               |
| Patching              | Reviewed                        | Unattended upgrades enabled; six packages were upgradable at capture                                           | E-004               |
| Host listeners        | Reviewed                        | Public 22/80/443; app/database loopback; Ops Agent all-interface listeners firewall-blocked; LLNMR present     | E-004               |
| Host Nginx            | Tested/Reviewed                 | Installed config safely logs callback path without query; tracked file is stale and fails two edge regressions | E-002, E-003, E-012 |
| Web container         | Reviewed/Tested                 | Healthy; runs as root/default; writable filesystem; no resource limits/cap-drop                                | E-005, E-018        |
| API container         | Reviewed/Tested                 | Healthy; non-root Node user; capabilities dropped; no resource limits/read-only root                           | E-005, E-018        |
| ClamAV                | Tested                          | Current engine/signatures; EICAR rejected; container hardening/limits incomplete                               | E-005, E-016        |
| PostgreSQL            | Reviewed/Tested                 | 16.14, Docker-internal/loopback; API uses superuser; audit chain valid                                         | E-006               |
| Provisioning broker   | Reviewed/Tested in clone        | Read-only, isolated, capped; identity sequence is defective at caller boundary                                 | E-005, E-015        |
| Documents bucket      | Reviewed                        | PAP, UBLA, versioning, 30-day soft delete; no retention lock                                                   | E-007               |
| Backup bucket         | Reviewed                        | PAP, UBLA, versioning, 7-day retention, 30-day soft delete; lifecycle gaps for releases/baselines              | E-007               |
| Secret Manager        | Reviewed                        | Five single enabled versions; only Microsoft credential has a 90-day rotation schedule                         | E-008               |
| Logging and alerting  | Reviewed/Tested                 | Uptime healthy; custom health metrics stale/incorrect; detection gaps                                          | E-010               |
| Backup creation       | Reviewed                        | Dump/manifest pairs, SHA-256, write-only SA, root-only current cleanup                                         | E-007               |
| Backup restore        | Reviewed; Not Verified runtime  | Safe design reviewed; not run outside 22:00–02:00 AST                                                          | E-020               |
| Incident response     | Reviewed; Not Verified exercise | Technical signals assessed; no complete tabletop or response-evidence package                                  | E-010               |

## 5.2 Roles and authorization personas

| Role/persona             | Source policy reviewed | Synthetic runtime tested | Production authenticated tested | Result                                   |
|--------------------------|------------------------|--------------------------|---------------------------------|------------------------------------------|
| Super Admin              | Yes                    | Yes                      | No credentials                  | Reviewed/Tested; production Not Verified |
| Admin                    | Yes                    | Yes                      | No credentials                  | Reviewed/Tested; production Not Verified |
| HR                       | Yes                    | Yes                      | No credentials                  | Reviewed/Tested; production Not Verified |
| CPO                      | Yes                    | Yes                      | No credentials                  | Reviewed/Tested; production Not Verified |
| COO                      | Yes                    | Yes                      | No credentials                  | Reviewed/Tested; production Not Verified |
| Manager                  | Yes                    | Yes                      | No credentials                  | Reviewed/Tested; production Not Verified |
| Line Manager             | Yes                    | Yes                      | No credentials                  | Reviewed/Tested; production Not Verified |
| Employee                 | Yes                    | Yes                      | No credentials                  | Reviewed/Tested; production Not Verified |
| Custom roles/inheritance | Yes                    | Yes                      | No credentials                  | Reviewed/Tested; production Not Verified |

The synthetic suite exercised direct-route denial, function permissions, BOLA/IDOR substitutions, department/team scope, self-service boundaries, custom-role behavior, soft-deletion paths, final-administrator protections, mass assignment, session revocation, CSRF, leave, document, payroll/financial, and approval flows.

## 5.3 Endpoint inventory

All discovered handler groups were reviewed for explicit public/permission policy. Authenticated active testing was performed in the clone; production remained unauthenticated/read-only.

| Controller group            | Route patterns | Coverage result                                                     | Evidence                   |
|-----------------------------|----------------|---------------------------------------------------------------------|----------------------------|
| Search                      | 1              | Reviewed/Tested                                                     | E-011, E-012               |
| Health                      | 1              | Reviewed/Tested in production                                       | E-011, E-014               |
| Approvals                   | 1              | Reviewed/Tested                                                     | E-011, E-012               |
| Attendance                  | 8              | Reviewed/Tested                                                     | E-011, E-012               |
| Announcements               | 10             | Reviewed/Tested, including cross-department denial                  | E-011, E-012, E-021        |
| Employees                   | 11             | Reviewed/Tested; Microsoft create/update defect reproduced          | E-011, E-015               |
| Audit, including 10 aliases | 20             | Reviewed/Tested                                                     | E-006, E-011, E-012        |
| Authentication              | 10             | Reviewed/Tested in clone; passive public routes in production       | E-011, E-012, E-014, E-016 |
| Departments                 | 5              | Reviewed/Tested                                                     | E-011, E-012               |
| Employment contracts        | 5              | Reviewed/Tested                                                     | E-011, E-012               |
| Documents                   | 6              | Reviewed/Tested with EICAR/MIME/size probes                         | E-011, E-012, E-016        |
| Positions                   | 5              | Reviewed/Tested                                                     | E-011, E-012               |
| Loans                       | 6              | Reviewed/Tested                                                     | E-011, E-012               |
| Operations                  | 29             | Reviewed/Tested                                                     | E-011, E-012               |
| Performance                 | 5              | Reviewed/Tested                                                     | E-011, E-012               |
| Salary records              | 5              | Reviewed/Tested                                                     | E-011, E-012               |
| Notifications               | 3              | Reviewed/Tested                                                     | E-011, E-012               |
| Payroll                     | 20             | Reviewed/Tested; ZAP SQLi alert manually rejected as false positive | E-011, E-012, E-017        |
| Service requests            | 13             | Reviewed/Tested                                                     | E-011, E-012               |

| Controller group      | Route patterns | Coverage result                                                                       | Evidence     |
|-----------------------|----------------|---------------------------------------------------------------------------------------|--------------|
| System administration | 24             | Reviewed/Tested                                                                       | E-011, E-012 |
| Leave requests        | 3              | Reviewed/Tested                                                                       | E-011, E-012 |
| Leave balances        | 5              | Reviewed/Tested                                                                       | E-011, E-012 |
| Leave workflow        | 16             | Reviewed/Tested                                                                       | E-011, E-012 |
| Leave types           | 5              | Reviewed/Tested                                                                       | E-011, E-012 |
| <b>Total</b>          | <b>217</b>     | <b>207 handler definitions; every handler explicit-public or permission-decorated</b> | E-011        |

The only public application routes were health, local login, Microsoft login start, and Microsoft callback. Swagger routes were unavailable at the production edge. /.env, /backup.sql, source maps, and random paths returned masked 404; protected employee and system routes returned 401 without a session.

## 5.4 Integrations

| Integration                       | Result                     | Observation                                                                               | Evidence            |
|-----------------------------------|----------------------------|-------------------------------------------------------------------------------------------|---------------------|
| Microsoft Entra SSO               | Reviewed/Tested in clone   | Strong OIDC validation; no live CA policies; Security Defaults Not Verified               | E-009, E-012        |
| Microsoft provisioning app/broker | Reviewed/Tested in clone   | Broker isolation good; caller sequencing fails new and changed-corporate-email invariants | E-005, E-009, E-015 |
| Exchange Online mail              | Reviewed/Tested            | Mail.Send constrained by Exchange Application RBAC; positive/negative baseline passed     | E-009, E-012        |
| Google Cloud Storage              | Reviewed/Tested indirectly | Buckets private; upload/download access reviewed; objectAdmin breadth remains             | E-007, E-012        |
| ClamAV                            | Tested                     | EICAR rejected; benign content masquerading as PNG accepted                               | E-016               |
| Cloud Logging/Monitoring          | Reviewed/Tested            | Collection present; health and security detections incomplete                             | E-010               |

## 5.5 Scheduled and operational jobs

| Job/control                               | Result                                                           | Evidence     |
|-------------------------------------------|------------------------------------------------------------------|--------------|
| Database backup creation and manifest     | Reviewed; recent pair observed                                   | E-007        |
| GCS hourly/daily/weekly/monthly lifecycle | Reviewed                                                         | E-007        |
| Backup restore drill                      | Script Reviewed; runtime Not Verified outside approved window    | E-020        |
| Audit retention/prune service and timer   | Reviewed                                                         | E-004, E-006 |
| Microsoft credential-expiry monitoring    | Reviewed; stale for approximately eight days                     | E-010        |
| API/tunnel health monitoring              | Reviewed; metrics incorrectly reported unhealthy                 | E-010        |
| Certificate renewal                       | Reviewed; certificate valid with approximately 54 days remaining | E-003        |
| Unattended OS upgrades                    | Reviewed                                                         | E-004        |
| ClamAV signature refresh                  | Reviewed/Tested current                                          | E-005, E-016 |
| Cloud Ops Agent collection                | Reviewed                                                         | E-010        |

## 6. Confirmed findings

The risk register at CYBERSECURITY\_RISK\_REGISTER.csv is the authoritative row-level remediation tracker. The findings below summarize the attack path, evidence, impact, and required acceptance condition.

## CYB-001 — High — Super Administrator can bypass recent step-up authentication

**Evidence:** The shared step-up helper explicitly returns success for user `.isSuperAdmin`, and regression tests assert that behavior. Production contains an active local-login Super Administrator with a password and active sessions. The account identity is excluded from this report. **Attack path:** Steal/reuse the local administrator password or session → invoke a sensitive administrative operation → application suppresses the recent-step-up requirement because the caller is Super Admin. **Impact:** A single credential/session compromise can become tenant-wide identity, payroll, document, or audit compromise without a second factor at the critical decision point. **Required fix:** Remove the bypass. Require fresh phishing-resistant Entra authentication or a documented, separately controlled break-glass procedure with vaulting, alerting, short activation, and post-use review. Revoke existing local Super Admin sessions after rollout. **Acceptance:** Every sensitive endpoint rejects stale/non-step-up Super Admin sessions; break-glass use creates a high-severity alert and immutable review record.

## CYB-002 — High — API connects to PostgreSQL as the postgres superuser

**Evidence:** Runtime connection metadata resolves to postgres; least-privileged `hr_erp_app` and `migrator` roles already exist. Public schema `CREATE` is revoked, but the API's superuser identity bypasses that boundary. **Attack path:** Exploit an API injection/RCE/deserialization/dependency flaw → inherit database superuser authority → read/modify all HR data, disable integrity controls, alter roles, or tamper with audit state. **Impact:** Application compromise becomes complete database compromise and materially weakens recovery/forensics. **Required fix:** Use `hr_erp_app` at runtime and a distinct, time-bounded migration identity. Grant only required schema/table/sequence/function permissions. **Acceptance:** Runtime `current_user` is non-superuser; migrations still work only with the migrator; negative permission tests prove the API cannot create roles, disable triggers, or access unneeded schemas.

## CYB-003 — High — Plaintext backups and HR PDFs exist in operator/deployment directories

**Evidence:** Historic plaintext SQL/ZIP backups exist in an ignored local OneDrive path and `/opt/medtech-hr-erp/backups`; live backup files were mode `0644`. The deployment root contains generated payslip/profile/settlement PDFs, some mode `0666`, under a group-accessible `0775` source directory. Only metadata was inspected. **Attack path:** Compromise a synced workstation account, stale host account, Docker-group principal, or ordinary local process → read database dumps/HR documents or modify world-writable PDFs → exfiltrate or tamper outside normal application authorization/auditing. **Impact:** Bulk disclosure of identity, payroll, banking, and document data; integrity loss; uncontrolled retention; breach-notification exposure. **Required fix:** Inventory and securely remove unapproved copies after legal/retention approval; quarantine necessary copies in encrypted, access-logged storage; set least-privileged ownership/modes; prevent generated documents from landing in source/deployment roots. **Acceptance:** Approved DLP/file inventory finds no raw SQL or employee PDF outside governed stores; deployment artifacts are non-sensitive; modes and ownership are enforced in deployment checks.

## CYB-004 — High — Security monitoring is incomplete and health metrics are stale/incorrect

**Evidence:** Custom `api_healthy` reported `0` because the probe omitted the required virtual-host header; `tunnel_healthy` reported `0` despite Cloudflare being intentionally inactive; Microsoft credential-expiry metrics stopped for approximately eight days. Alert policies exist, but explicit detections for privilege changes, audit tampering, secret-access anomalies, container compromise, and exfiltration were absent. **Attack path:** Attack or control failure occurs → monitoring is already noisy/stale or lacks the use case → responders miss or discount the signal. **Impact:** Increased dwell time, late breach discovery, weak incident reconstruction, and unreliable operational assurance. **Required fix:** Repair probes, retire obsolete tunnel checks, add freshness alerts, and implement/test the missing detection cases with runbooks and owners. **Acceptance:** Synthetic signals trigger the intended alert/channel within the defined SLA; stale metrics alert; dashboards show current healthy state; quarterly detection tests are recorded.

## CYB-005 — High — Microsoft employee onboarding/login enablement violates the identity-binding sequence

**Evidence:** Exact-schema synthetic integration failed because corporate-user creation attempts `microsoftLoginEnabled=true` before a Microsoft object ID exists, violating `User_microsoft_login_requires_object_id`. Updating an existing employee to a corporate email clears the object ID but does not safely complete/rebind provisioning before login enablement. The resulting operator response is 500. Remaining authorization tests passed only after a clone-only removal of that constraint; production was never altered. **Attack path:** Create a new corporate employee or change an existing employee to `@med-tech.com` → local transaction attempts an identity state prohibited by the database → onboarding fails or becomes partially provisioned/orphaned → operators may retry or seek unsafe manual workarounds. **Impact:** Denial of Microsoft login, orphaned Entra/local identities, inconsistent access revocation, and risk of future misbinding if the constraint is weakened instead of fixing the sequence. **Required fix:** Provision/resolve Entra first, persist the exact tenant/object ID binding, then enable Microsoft login. Apply the same shared flow to new onboarding and corporate-email transition. Compensate/rollback if any step fails; retain the database constraint. **Acceptance:** Automated tests cover both required flows, retries, Graph failure, duplicate mail/UPN, rollback, and wrong-object prevention; successful users can sign in and failures remain disabled with a controlled non-500 error.

## CYB-006 — Medium — Production is directly exposed without the expected Cloudflare/WAF layer

**Evidence:** DNS resolves directly to the VM public IP; Cloudflare tunnel is inactive; worldwide TCP 80/443 reaches host Nginx. Application throttling and Nginx/Helmet controls mitigate but do not replace managed edge filtering. **Attack path:** Internet attacker targets the origin directly, bypassing expected managed WAF/bot/DDoS controls. **Impact:** Greater attack surface, origin exposure, and reliance on a single VM/application for volumetric and automated abuse resistance. **Required fix:** Either restore an approved Cloudflare/private-origin design or explicitly adopt and harden the direct-origin design with managed load balancing/WAF, origin restriction, rate controls, and monitored DDoS posture. **Acceptance:** Origin is unreachable except through the approved edge, or the direct design has approved compensating controls and tested runbooks.

## CYB-007 — Medium — Upload validation accepts content that does not match the declared MIME type

**Evidence:** The clone accepted benign non-PNG bytes uploaded with an allowed PNG declaration and marked the object CLEAN. EICAR was correctly rejected, and oversized upload returned 413. Source review showed extension/declared-MIME checks without a content-signature match. **Attack path:** Upload active or misleading content under an allowed MIME/extension → pass current allowlist and malware scan → later consumer/parser handles content differently than the serving layer. **Impact:** Stored-content confusion, downstream parser exploitation, unsafe sharing, and weakened document trust. `nosniff` and attachment behavior reduce immediate browser exploitability. **Required fix:** Detect file type from magic bytes/content, compare against declared MIME and extension, reject mismatches, and preserve safe download headers. **Acceptance:** Mismatch, polyglot, truncated, renamed, EICAR, and oversized fixtures are rejected/quarantined; valid formats continue to work.

## CYB-008 — Medium — Container hardening, resource controls, and image provenance are incomplete

**Evidence:** Web and ClamAV run without the strongest identity/capability/filesystem controls; major services lack CPU/memory/PID limits; most root filesystems are writable; images use mutable tags or local image IDs without signed provenance/digest policy. The broker is materially better hardened. **Attack path:** Compromise a container → write persistence/tooling, exhaust host resources, or exploit excessive container authority → affect co-located services. **Impact:** Expanded blast radius and availability risk on the single production VM. **Required fix:** Run non-root where supported, drop capabilities, add `no-new-privileges`, read-only root filesystems/tmpfs, limits, health-aware restart policies, digest pinning, SBOM/provenance, and vulnerability gates. **Acceptance:** Compose regression verifies controls; bounded load cannot starve PostgreSQL/host; deployment admits only approved digests.

## CYB-009 — Medium — Backup/release/security-baseline retention exceeds governed lifecycle

**Evidence:** Backup lifecycle rules cover hourly/daily/weekly/monthly prefixes, while releases and security-baselines contain duplicate database, document, certificate, source, and screenshot artifacts outside those rules. Documents have no retention lock; backups have a seven-day retention policy and thirty-day soft deletion. **Attack path:** Long-lived duplicate copies accumulate → a later credential/bucket compromise exposes a larger historical dataset → deletion/subject-retention obligations become difficult to enforce. **Impact:** Enlarged breach scope and non-compliant data retention. **Required fix:** Classify each prefix, prohibit PII/secrets/screenshots in release artifacts, apply owned lifecycle/retention, and test deletion/legal-hold behavior. **Acceptance:** Every prefix has owner, data classification, maximum retention, lifecycle rule, and sampled content validation.

## CYB-010 — Medium — Secret rotation and expiry governance is incomplete

**Evidence:** Five secrets had a single enabled version. Only the Microsoft client credential had a 90-day rotation schedule; JWT, database, audit-HMAC, and recovery-bootstrap secrets lacked equivalent schedule/expiry metadata. Values were not read. **Attack path:** Long-lived secret leaks through process, host, backup, or operator access → remains usable indefinitely or for an excessive period. **Impact:** Prolonged unauthorized access and difficult incident containment. **Required fix:** Define rotation/overlap/revocation procedures per secret; automate where safe; test dual-version rollout; alert on age and access anomalies. Preserve audit-HMAC verification during planned rotation. **Acceptance:** Secret inventory shows owner, purpose, maximum age, last/next rotation, monitored access, and successful rollback test.

## CYB-011 — Medium — Entra governance lacks verified tenant-wide access policy and application ownership

**Evidence:** No live Conditional Access policies were returned. Security Defaults was permission-denied and remains Not Verified. SSO, provisioning, and mail applications had zero owners. Authorization policy prevented risky consent and ordinary application/security-group creation; Exchange Application RBAC correctly constrained mail. **Attack path:** Administrative account or application credential is compromised → no verified tenant-wide MFA/device/location/risk condition and no accountable app owner → response/renewal is delayed. **Impact:** Identity compromise and application lifecycle gaps. **Required fix:** Assign at least two accountable owners per enterprise app, verify Security Defaults/Conditional Access, require MFA/phishing-resistant admin auth, document break-glass exclusions, and monitor credential/consent changes. **Acceptance:** Read-only evidence shows approved policies, protected administrator/user populations, tested break-glass, and owned applications.

## CYB-012 — Medium — Administrative host access lacks OS Login 2FA and retains stale Docker-group users

**Evidence:** OS Login is enabled but `enable-oslogin-2fa` is false. Two locked local users remain in the Docker group; Docker membership is root-equivalent. The current OS Login administrator has passwordless sudo. SSH root/password login is disabled and IAP firewall scoping is good. **Attack path:** Compromise an eligible cloud identity/key or reactivate/abuse a stale account → gain VM administrative or Docker-root access without a host-level second-factor enforcement signal. **Impact:** Full host, container, database, and secret-access compromise. **Required fix:** Enforce OS Login 2FA/strong Conditional Access, remove stale accounts/group memberships after owner validation, and alert on sudo/Docker use. **Acceptance:** No unowned local Docker users; interactive admin access requires strong MFA; quarterly access review evidence exists.

## CYB-013 — Medium — Tracked and installed edge configuration are not reconciled

**Evidence:** Installed Nginx includes direct API proxying, safe callback logging via `$uri`, and default denial; tracked `ops/hr-med-tech-http.conf` differs and fails two of three edge regressions. Installed behavior was safer than the stale source. **Attack path:** Future redeploy/rollback uses tracked config → silently removes live hardening or restores unsafe callback logging/routing behavior. **Impact:** Security regression and non-reproducible disaster recovery. **Required fix:** Reconcile the installed config into source, remove obsolete variants after evidence retention, and gate deployment on the edge regression against the actual artifact. **Acceptance:** Installed and tracked hashes match; all edge tests pass in CI and post-deploy verification.

## CYB-014 — Medium — Twenty PostgreSQL constraints remain NOT VALID

**Evidence:** Schema metadata contained twenty unvalidated constraints. New writes are generally checked, but historical rows have not been proven conformant. **Attack path:** Existing inconsistent relationship/state remains latent → authorization, payroll, leave, or identity logic assumes integrity that was never validated. **Impact:** Data-integrity failure, workflow bypass, migration outage, or incorrect authorization decisions. **Required fix:** Identify violations read-only, remediate under change control, then VALIDATE CONSTRAINT in bounded batches with rollback/monitoring. **Acceptance:** Zero unintended NOT VALID constraints and integrity regression checks pass on a restored production copy.

## CYB-015 — Medium — Supported dependency vulnerabilities remain in production dependency graphs

**Evidence:** Frontend production dependencies had no audit finding. Frontend development dependencies had four High advisories. Backend production graph included a High `js-yaml` path through Swagger and a Moderate `DOMPurify` path through `jsPDF`. `Semgrep` and `Trivy` did not independently prove exploitability. **Attack path:** Vulnerable build/test/parser/API-documentation/PDF path processes attacker-influenced content → dependency flaw is triggered. **Impact:** Varies from development compromise to server-side data or code impact; reachability must be confirmed per advisory. **Required fix:** Upgrade within compatible ranges, remove unreachable packages where unused, and run targeted regression/reachability tests. **Acceptance:** Production and developer audits are clean or each exception has owner, reachability evidence, expiry, and compensating control.



## CYB-016 — Medium — Backend CSV exports do not neutralize spreadsheet formulas

**Evidence:** Backend CSV quoting handles delimiters/quotes but does not neutralize leading =, +, -, or @; a frontend export helper does. No malicious production record was created. **Attack path:** Attacker-controlled text enters an exported field → privileged user opens CSV in spreadsheet software → formula/DDE-style content executes or prompts external interaction. **Impact:** Operator workstation data exfiltration or unsafe command/link execution depending on spreadsheet controls. **Required fix:** Reuse a single server-side neutralization rule before CSV quoting; preserve raw data in non-spreadsheet APIs. **Acceptance:** Fixtures beginning with formula trigger characters render as inert text in Excel/LibreOffice and round-trip safely.

## CYB-017 — Low — Internal PostgreSQL transport is not encrypted

**Evidence:** PostgreSQL SSL was off. The service is limited to the Docker network and host loopback, and SCRAM authentication is used. **Attack path:** Compromise another container/host network plane → observe or manipulate internal database traffic. **Impact:** HR data and credentials could be exposed after an initial local compromise. **Required fix:** Enable authenticated TLS for PostgreSQL or document/approve equivalent single-host isolation with stronger container/network segmentation. **Acceptance:** Clients verify the database certificate and reject plaintext, or an approved risk exception demonstrates equivalent isolation and monitoring.

## CYB-018 — Low — Assurance scripts and lint are not consistently green

**Evidence:** The final frontend suite/build and RBAC tests passed. The announcements package script was missing, team-hierarchy regression referenced a removed method and ran zero passing cases, edge regression failed against the stale tracked Nginx file, and lint reported two errors plus thirteen warnings. **Attack path:** Security-sensitive behavior changes while stale or missing checks create false confidence. **Impact:** Increased probability of an authorization/configuration regression escaping review. **Required fix:** Repair or remove stale scripts, wire required tests to CI, and make non-rewriting lint/build/security checks deterministic. **Acceptance:** Documented security test command runs all intended suites and exits cleanly on a clean checkout.

## CYB-019 — Low — Host discovery/agent listeners are broader than needed

**Evidence:** LLMNR listened on UDP/TCP 5355; Ops Agent endpoints bound all interfaces on 20201/20202 although GCP firewall rules blocked external access. Application and database listeners were loopback/Docker scoped. **Attack path:** A future firewall or local-network change makes management/discovery services reachable. **Impact:** Additional discovery, spoofing, or agent attack surface. **Required fix:** Disable unused LLMNR and bind agent endpoints to loopback where supported; keep firewall regression checks. **Acceptance:** Listener inventory contains only documented addresses/ports and an external scan confirms denial.

## CYB-020 — Low — Default log retention and key management need a documented decision

**Evidence:** \_Default retained logs for 30 days; \_Required retained 400 days and was locked. No log-bucket CMEK was configured. **Attack path:** An incident is discovered after default retention or requires customer-controlled key revocation → detailed evidence is unavailable or key control does not meet policy. **Impact:** Reduced forensics and potential policy mismatch. **Required fix:** Align per-log retention with detection/legal requirements; route high-value security logs to an access-controlled longer-retention bucket and adopt CMEK only if policy requires it. **Acceptance:** Retention matrix, cost approval, access review, and recovery/search test are documented.

# 7. Attack-path analysis

## 7.1 Local administrator compromise to tenant-wide control

- 1 Obtain the active local Super Administrator password or session.
- 2 Bypass recent-step-up because the code explicitly exempts Super Admin.
- 3 Invoke sensitive system/identity functions.
- 4 Monitoring may not reliably detect privilege changes.
- 5 Use the API's database-superuser connection or application privileges to expand impact.

**Break points:** strong Entra-only admin authentication, no step-up bypass, short/revocable sessions, least-privileged DB user, and privilege-change alerts.

## 7.2 Host/operator compromise to bulk HR data

- 1 Compromise a synced OneDrive identity, stale local/Docker-group account, or administrative host identity.
- 2 Read plaintext SQL backups and generated payroll/profile PDFs outside application authorization.
- 3 Exfiltrate historical/current data without application audit events.

**Break points:** eliminate uncontrolled copies, least-privileged file modes, governed encrypted storage, DLP inventory, OS Login MFA, and host/file access detection.

## 7.3 Internet abuse against a directly exposed origin

- 1 Resolve the public origin directly.
- 2 Send credential abuse, resource pressure, or application exploits without a managed edge/WAF.
- 3 Attempt container/resource exhaustion on a single host where service limits are absent.

**Break points:** approved managed edge/origin restriction, durable throttles, container/host limits, autoscaling or isolation, and attack telemetry.

## 7.4 Identity onboarding inconsistency

- 1 Create an employee with corporate mail or change an existing employee to @med-tech.com.
- 2 Application enables Microsoft login before Entra object binding is complete.
- 3 Database correctly rejects the invalid state and the operator receives 500.
- 4 Retried/manual remediation can leave orphaned identities unless the workflow is idempotent and compensating.

**Break points:** one shared onboarding orchestrator, exact tenant/object binding, idempotency key, controlled compensation, constraint retained, and explicit state machine/audit events.

## 8. Automated-analysis and manual-triage ledger

| Tool/check                                                        | Result                                                                  | Manual disposition                                                                                                                                                                                                      |
|-------------------------------------------------------------------|-------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Frontend tests                                                    | 17 files, 72 tests passed on final source                               | Accepted                                                                                                                                                                                                                |
| Frontend production build                                         | Passed; large-chunk warning                                             | Accepted; performance-only warning                                                                                                                                                                                      |
| Backend RBAC regression                                           | 11/11 passed on final source                                            | Accepted, including cross-department announcement denial                                                                                                                                                                |
| Backend security regression                                       | 24 passed                                                               | Accepted                                                                                                                                                                                                                |
| Leave/document/provisioning/linking/audit/financial/hybrid suites | Passed; one non-security skip recorded                                  | Accepted                                                                                                                                                                                                                |
| Exact-schema integration                                          | Failed at Microsoft-login/object-ID constraint                          | Confirmed CYB-005                                                                                                                                                                                                       |
| Integration after clone-only constraint removal                   | 1/1 full multi-role flow passed                                         | Accepted only for remaining control coverage; not evidence that the constraint should be removed                                                                                                                        |
| Semgrep 1.175 p/security-audit                                    | 353 files, 40 rules, one Nginx proxy finding                            | False positive after installed/source/manual review                                                                                                                                                                     |
| Gitleaks 8.30.1 history                                           | 289 commits, 62.84 MB, zero findings                                    | Accepted for Git history; ignored backup directories were outside this result and manually identified                                                                                                                   |
| Trivy 0.74 filesystem/laC                                         | Dependency findings; web-root/container-health findings                 | Dependency results retained; root-user issue confirmed; missing-healthcheck result false because Compose defines health                                                                                                 |
| npm audit                                                         | Frontend prod 0; frontend dev 4 High; backend High/Moderate paths       | CYB-015, reachability/upgrade required                                                                                                                                                                                  |
| ZAP 2.17 active API                                               | 0 Fail, 6 Warn, 116 Pass                                                | SQLi alert false positive (401 for all requests); full-path alert matched route text; CORP same-site is a hardening note; OIDS 500 caused intentionally absent clone Microsoft config; no scanner-only finding accepted |
| Custom active probes                                              | Expected session/CSRF/EICAR/size/DTO/rate behavior; MIME spoof accepted | CYB-007 confirmed                                                                                                                                                                                                       |

### ZAP false-positive detail

ZAP labeled one unauthenticated payroll-adjustment probe as SQL injection. The report and scan output show the endpoint returned 401 Unauthorized; no authenticated data, SQL error, timing proof, or differential database behavior was obtained. Source review uses typed DTO validation and ORM/database access patterns. The alert is rejected as unconfirmed scanner noise. This does not replace future authenticated DAST in a clone.

## 9. Control-framework mapping

Mappings are technical control-gap mappings, not certification statements. Exact applicability and legal interpretation remain the organization's responsibility.

| Audit theme                            | OWASP ASVS 5.0.0                                       | OWASP API Top 10 2023 | NIST CSF 2.0        | CIS Controls 8.1 | CIS GCP Foundation 5.0.0   | Qatar NIA 2.0 / Law 13 of 2016                   |
|----------------------------------------|--------------------------------------------------------|-----------------------|---------------------|------------------|----------------------------|--------------------------------------------------|
| Admin MFA/step-up and sessions         | V6.3.3, V7.2.4, V7.4.1, V7.5.1                         | API2, API5            | PR.AA, DE.CM        | 5, 6, 8          | IAM                        | NIA Access Control; Law Arts. 8, 13              |
| Least-privileged DB/service identities | V13.2.2, V13.3.1, V13.3.2                              | API8                  | PR.AA, PR.DS        | 5, 6, 12, 16     | IAM, Compute, Database     | NIA Access Control/Operations; Arts. 8, 13       |
| Sensitive files, retention, backups    | V12.3.1, V14.1.2                                       | API3, API8            | ID.AM, PR.DS, RC.RP | 3, 11            | Storage, Logging           | NIA Asset/Data/BCM; Arts. 8, 10, 13, 14          |
| Monitoring and incident detection      | V16.1.1, V16.3.2, V16.3.3                              | API8, API10           | DE.CM, DE.AE, RS.MA | 8, 13, 17        | Logging and Monitoring     | NIA Incident Management; Arts. 11, 14            |
| Microsoft identity onboarding          | V6.3.3, V7.4.1, V7.5.1, V13.3.2                        | API2, API5, API6      | GV.RM, PR.AA        | 5, 6, 16         | IAM                        | NIA Access Control/Acquisition; Arts. 8, 13      |
| Edge/config/container hardening        | V13.4.2, V13.4.7, V15.3.4                              | API4, API8, API9      | PR.PS, PR.IR        | 4, 7, 12, 13     | Networking, Compute        | NIA Communications/Operations; Art. 13           |
| Upload validation                      | V5.1.1, V5.2.1, V5.2.2, V5.2.4, V5.3.2, V5.4.2, V5.4.3 | API3, API4, API8      | PR.DS, PR.PS        | 3, 10, 16        | Storage                    | NIA Operations/Application Security; Arts. 8, 13 |
| CSV/spreadsheet injection              | V1.2.10                                                | API3                  | PR.DS               | 3, 16            | Application responsibility | NIA Application Security; Arts. 8, 13            |
| Anti-automation/rate limiting          | V2.4.1                                                 | API2, API4, API6      | PR.AA, DE.CM        | 6, 13, 16        | Networking/Monitoring      | NIA Access Control/Monitoring; Art. 13           |
| Security testing and inventory         | V1–V17 as applicable                                   | API9                  | GV.RM, ID.AM, ID.RA | 1, 2, 7, 16, 18  | All benchmark domains      | NIA Governance/Compliance; Art. 11               |

Official references:

- [OWASP ASVS 5.0.0](#)
- [OWASP API Security Top 10 2023](#)
- [NIST Cybersecurity Framework 2.0](#)
- [CIS Controls 8.1](#)
- [CIS Google Cloud Foundation Benchmark 5.0.0](#)
- [Qatar National Information Assurance Policy 2.0](#)
- [Qatar Law No. 13 of 2016](#)

## 10. Remediation roadmap

### Immediate containment and first 7 days

- Restrict, monitor, and prepare to replace the local password-only Super Admin; review/revoke unnecessary active sessions.
- Lock down sensitive file modes and access immediately; inventory before any deletion so retention/legal requirements are honored.
- Repair the broken API/tunnel/credential-expiry monitoring signals so operators can trust current dashboards.
- Freeze any proposal to weaken `User_microsoft_login_requires_object_id`; document the required onboarding invariant.
- Confirm no uncontrolled Entra/manual workaround was used for failed corporate onboarding.

### Within 30 days

- Remove the Super Admin step-up bypass and implement protected break-glass.
- Cut the API over to `hr_erp_app`; verify migrations use the migrator.
- Implement and test atomic Microsoft new-hire and corporate-email-transition onboarding.
- Move/remove plaintext backups and generated HR PDFs from OneDrive/deployment roots under approved data-handling procedure.
- Add critical identity, audit, secret, malware, container, and exfiltration detections with runbooks.

### Within 90 days

- Establish an approved edge/WAF/origin design.
- Enforce OS Login MFA and complete local/Docker-group access review.
- Reconcile tracked/live Nginx configuration.
- Validate all intended PostgreSQL constraints on a restored clone, then in production change control.
- Add magic-byte/MIME-match upload validation.
- Apply container limits/hardening and image provenance controls.
- Close supported dependency advisories and CSV formula injection.
- Establish owned secret, backup-prefix, log-retention, and Entra-app lifecycle policies.

### Owned backlog

- Remove unused LLMNR/all-interface agent binds.
- Decide CMEK/high-value log retention based on policy and cost.
- Repair stale test/lint entry points and maintain one documented security verification command.

## 11. Residual risk and explicitly Not Verified controls

| Control                                        | Status       | What is needed to verify                                                                               |
|------------------------------------------------|--------------|--------------------------------------------------------------------------------------------------------|
| Production login/logout/session expiry/step-up | Not Verified | Designated non-PII test accounts and supervised login-only production window                           |
| Production cross-role reads                    | Not Verified | Approved test personas and read-only object set                                                        |
| Microsoft Security Defaults                    | Not Verified | Graph permission/read-only tenant evidence                                                             |
| Conditional Access effectiveness               | Not Verified | Policy export plus sign-in simulation/evidence                                                         |
| GCP organization policies                      | Not Verified | Organization-level read permission/API availability                                                    |
| Exact production-image CVE inventory           | Not Verified | Registry/export access to immutable production image digest                                            |
| Backup restore RTO/data correctness            | Not Verified | Run existing drill during 22:00–02:00 AST, record elapsed time/checksums/cleanup and production health |
| Full incident response readiness               | Not Verified | Tabletop covering identity compromise, ransomware, data exfiltration, and cloud credential theft       |
| Vendor/physical/HR controls                    | Not Verified | Organizational policies, contracts, evidence, and interviews                                           |
| Legal compliance/certification                 | Not Verified | Qualified legal/compliance assessment; this report is technical only                                   |

## 12. Production safety and cleanup attestation

- No audit-caused production deployment, configuration, secret, IAM, container, database, or HR-record change occurred.
- Production activity was passive/read-only; no login credentials were supplied and no audit session write was created.
- The active clone used synthetic identities, an isolated network, transient containers, temporary PostgreSQL state, and no exposed application host port.
- Clone cleanup left no matching containers, networks, volumes, or images.
- The audit VM `hr-erp-audit-20260831` and its auto-delete boot disk were deleted; a subsequent instance listing returned no match.
- Active-result files were copied locally and SHA-256 hashed before deletion. Raw results are excluded from deliverables.
- Final production `/healthz` and `/api/v1/health` returned `200`; all Compose services were healthy; memory and disk stop thresholds were comfortably satisfied.
- The restore drill was not run because the approved 22:00–02:00 AST window was not active. No unsupported schedule workaround was attempted.

## 13. Conclusion

MedTech HR ERP has credible controls at the application boundary: explicit route authorization, robust session/CSRF behavior, strong OIDC validation, private buckets, guarded backups, a validated audit chain, malware scanning, and meaningful automated tests. The dominant residual risk lies in privileged identity handling, database/runtime privilege, uncontrolled sensitive copies, and weak operational detection—not in a reproduced public unauthenticated exploit.

The Microsoft login requirement should be implemented by preserving the database invariant and correcting the orchestration: Entra provision/resolve → bind exact object ID → enable Microsoft login, for both new corporate employees and existing employees changed to corporate mail. That fix belongs in a controlled remediation change after this audit; it was not silently patched or deployed as part of evidence collection.

# Post-Audit Remediation Addendum

Repository and workstation remediation completed on 31 August 2026. Production was not changed. Findings remain open until live acceptance tests and required owner approvals are evidenced.

| PRODUCTION | SOURCE                           | CLOSURE                              |
|------------|----------------------------------|--------------------------------------|
| UNCHANGED  | IMPLEMENTED AND LOCALLY VERIFIED | LIVE EVIDENCE / OWNER ACTION PENDING |

## Implementation and closure ledger

| Finding | Implemented or contained                                                                                                                                                                                                                                     | Remaining closure evidence                                                                                                                                  |
|---------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------|
| CYB-002 | Separate hr_erp_app and hr_erp_migrator identities, explicit grants/default privileges, no runtime migrations, and migration-metadata denial.                                                                                                                | Create the two Secret Manager credentials, validate on a restored clone, deploy, and prove runtime current_user is non-superuser.                           |
| CYB-003 | Sensitive build artifacts are excluded; deployment containment enforces restrictive modes. Fourteen local backup/PDF paths are restricted to the owner, SYSTEM, and Administrators without deletion.                                                         | Complete Data Protection classification, legal-hold review, governed relocation/disposal, live mode enforcement, and DLP inventory.                         |
| CYB-004 | Health and security telemetry now covers direct API, TLS edge, database, publisher freshness, auth failures, authorization denials, privilege changes, audit-chain state, scanner failures, and secret age. Alert reconciliation preserves the live channel. | Deploy, emit synthetic signals, verify delivery/runbooks, and obtain approval for cloud-native secret-access and exfiltration detections.                   |
| CYB-006 | Direct-origin Nginx hardening and a private-origin migration runbook are ready.                                                                                                                                                                              | Cloudflare/network owner approval, named-tunnel credential, canary, DNS/firewall cutover, and external origin-denial proof.                                 |
| CYB-007 | The shared upload boundary validates extension, declared MIME, and PDF/JPEG/PNG/WebP/OOXML structure before scan/storage. Mismatch, truncation, rename, and OOXML polyglot regressions pass.                                                                 | Deploy and repeat the full upload fixture set in the disposable clone.                                                                                      |
| CYB-008 | Base images are digest-pinned and revision-labelled; web runs non-root; API/web use read-only roots, tmpfs, dropped capabilities, resource limits, and segmented networks; deployment records image IDs.                                                     | Run container/load/provenance checks in a working isolated engine before production. Local Docker Desktop crashed before its Linux engine became available. |
| CYB-009 | Retention policy forbids sensitive release artifacts and defines proposed release/baseline retention.                                                                                                                                                        | DPO/legal-hold classification of existing mixed release content before any lifecycle deletion.                                                              |
| CYB-010 | Secret owners, maximum ages, rollouts, and telemetry are documented. Audit events carry HMAC key IDs and retain configured verification keys across rotation.                                                                                                | Create the previous-key Secret Manager object, populate timestamps, and execute monitored rotation/rollback drills.                                         |
| CYB-011 | A safe Entra ownership, Conditional Access report-only, phishing-resistant admin, and break-glass procedure is documented.                                                                                                                                   | Authorized tenant administrators must apply and evidence it. Unavailable tenant controls remain Not Verified.                                               |
| CYB-012 | A lockout-safe OS Login 2FA and stale-account procedure is documented.                                                                                                                                                                                       | Named owners must validate MFA and dependencies before live metadata, account, sudo, or Docker-group changes.                                               |
| CYB-013 | The safer installed Nginx behavior is reconciled into source; deployment uses config test, health verification, and rollback. All three edge regressions pass.                                                                                               | Deploy and prove installed/tracked hashes match.                                                                                                            |
| CYB-014 | A bounded migration validates all 31 discovered unvalidated constraints with lock and statement timeouts.                                                                                                                                                    | Run integrity checks and the migration against a restored production copy before the live change window.                                                    |
| CYB-015 | Compatible lockfile updates remove the reported advisories. Full and production-only npm audits report zero vulnerabilities for frontend and backend.                                                                                                        | Merge, rebuild immutable images, and retain audit/provenance gates.                                                                                         |
| CYB-016 | One server-side CSV encoder neutralizes leading formula triggers before quoting; audit, payroll, and WPS exports use it and fixtures pass.                                                                                                                   | Deploy and complete the requested Excel/LibreOffice opening check.                                                                                          |

| Finding | Implemented or contained                                                                                                                                               | Remaining closure evidence                                                                                                       |
|---------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------|
| CYB-017 | PostgreSQL uses a private CA, verified postgres SAN, strict client verification, TLS-only HBA, plaintext rejection, segmented networking, and no production host port. | Validate certificates, roles, and migrations on the restored clone, then prove encrypted app sessions and plaintext denial live. |
| CYB-018 | Stale assurance entry points were repaired/removed; lint is non-rewriting; one security command runs authorization, upload, identity, leave, session, and edge checks. | Keep the command in merge and deployment gates.                                                                                  |
| CYB-019 | Boot-persistent host hardening disables LLMNR/mDNS and blocks Ops Agent self-metric ports from non-loopback interfaces while retaining local function.                 | Apply on the VM and verify listener/firewall inventory externally.                                                               |
| CYB-020 | A 90-day Default, locked 400-day Required, and Google-managed-encryption-unless-required decision is documented.                                                       | Security/Legal cost and key-ownership approval, followed by live retention/search/recovery evidence.                             |

LOCAL VERIFICATION

Frontend build and 72 tests; backend build and 68 security-suite tests; lint with zero errors (13 pre-existing warnings); four npm audits with zero advisories; Prisma generation; Compose configuration; shell and Python syntax; whitespace checks excluding pre-existing dirty graph artifacts.

ASSURANCE BOUNDARY

Runtime container, database-role, PostgreSQL TLS, and constraint-migration exercises remain pending because the local Docker Desktop Linux engine failed before an isolated stack could start. No production deployment, IAM, secret, database, firewall, DNS, retention, tenant, or host-identity change was made.